Light

Cyber Security — Threats

Over **1,100,000+ marks** of exam-aligned content across **67 qualifications**. 4,200+ auto-marked assessments & long-answer practice. No login required.

Assessment Hub | Notes / Textbook | Long-Answer Practice

Assessment Hub
Long-Answer
Notes Index
What you must know
Toolkit
1. Malware
2. Social engineering
3. Network attacks
Worked examples
Quick reference
Typical pitfalls

OCR GCSE Computer Science — **Cyber Security: Threats to Systems and Networks (J277/01 Section 1.4.1)**. This topic covers the different forms of attack that threaten computer systems including malware types, social engineering techniques, brute-force attacks, denial of service attacks, data interception and theft, and SQL injection.
Exam questions typically ask you to **describe** different types of malware, **explain** how social engineering attacks work, **identify** threats from given scenarios, and **compare** different attack methods. The 2024 exam included questions about identifying attack types from descriptions and explaining how specific attacks compromise systems.

What you must know

This checklist covers the key exam-visible concepts. You should be able to explain each point and apply it to real-world scenarios.

- **Define** malware and explain its purpose.
- **Describe** five types of malware: virus, worm, trojan, spyware, ransomware.
- **Explain** how each type of malware spreads and what damage it causes.
- **Define** social engineering and explain why it targets humans rather than technology.
- **Describe** four social engineering techniques: phishing, blagging, pharming, shouldering.
- **Explain** how brute-force attacks work and why they succeed against weak passwords.

- **Describe** denial of service (DoS) attacks and their effect on systems.
- **Explain** data interception and theft, including man-in-the-middle attacks.
- **Describe** SQL injection attacks and how they exploit vulnerable websites.
- **Identify** the type of attack from a given scenario or description.

> **Specification note.** OCR J277 Section 1.4.1 covers threats to computer systems and networks. Questions often present scenarios describing an attack and ask you to identify the attack type, explain how it works, or describe its impact. Being able to distinguish between similar attacks (e.g., phishing vs pharming) is essential.

Toolkit

Malware types at a glance

Malware type	How it spreads	What it does	Key characteristic
Virus	Attaches to files; spreads when files are shared/opened	Corrupts/deletes files, damages system	Requires user action to spread
Worm	Self-replicates across networks automatically	Consumes bandwidth, installs backdoors	Spreads without user action
Trojan	Disguised as legitimate software	Creates backdoor for attacker access	Appears harmless but isn't
Spyware	Bundled with software, drive-by downloads	Monitors activity, steals data	Operates secretly/hidden
Ransomware	Email attachments, malicious downloads	Encrypts files, demands payment	Holds data hostage

Social engineering techniques

Technique	Method	Example
Phishing	Fake emails/messages pretending to be legitimate organisations	Email claiming to be from your bank asking you to verify your account
Blagging (pretexting)	Creating a fabricated scenario to obtain information	Calling IT support pretending to be an employee who forgot their password

Technique	Method	Example
Pharming	Redirecting users to fake websites without their knowledge	Typing your bank's URL but being redirected to a fake lookalike site
Shouldering	Observing someone entering sensitive information	Looking over someone's shoulder as they enter their PIN at a cash machine

Network attacks summary

Attack	How it works	Impact
Brute-force	Systematically tries all possible password combinations	Gains unauthorised access to accounts
Denial of Service (DoS)	Floods server with requests to overwhelm it	Website/service becomes unavailable
Data interception	Captures data as it travels across a network	Sensitive data stolen (passwords, card details)
SQL injection	Inserts malicious SQL code into website input fields	Access/modify/delete database contents

Exam tip: Learn the KEY CHARACTERISTIC that distinguishes each attack. Virus needs user action; worm spreads automatically. Phishing uses fake emails; pharming redirects at DNS level. Being precise about these differences earns marks.

1. Malware

Malware (malicious software) is any software designed to damage, disrupt, or gain unauthorised access to a computer system. Malware is created by cybercriminals to steal data, extort money, or cause damage. Understanding the different types helps you identify threats and protect systems.

1.1 Virus

A **virus** is malware that attaches itself to a legitimate file or program. When the infected file is opened or executed, the virus activates and can spread to other files.

How viruses spread:

- Attaching to executable files (.exe, .com)
- Infecting document macros (Word, Excel)
- Spreading via email attachments

- Copying to USB drives and shared files

What viruses do:

- Delete or corrupt files
- Slow down the computer
- Display unwanted messages or pop-ups
- Damage the operating system
- Spread to other computers

Key characteristic: A virus **requires user action** to spread — the user must open the infected file or run the infected program. It cannot spread on its own.

> **Real-world example:** The ILOVEYOU virus (2000) spread via email with the subject "I Love You" and an attachment. When users opened the attachment, the virus sent itself to everyone in their address book and overwrote files. It caused an estimated $10 billion in damage.

1.2 Worm

A **worm** is malware that self-replicates and spreads across networks without needing to attach to a file or requiring user action.

How worms spread:

- Exploiting vulnerabilities in operating systems or software
- Travelling across network connections automatically
- Sending copies of themselves via email
- Spreading through messaging applications

What worms do:

- Consume network bandwidth (slowing networks)
- Install backdoors for later access
- Delete files or corrupt data
- Install other malware (like ransomware)
- Create botnets (networks of infected computers)

Key characteristic: A worm **spreads automatically without user action**. Once a computer is infected, the worm finds other vulnerable computers and spreads to them independently.

> **Exam tip:** The key difference between virus and worm is HOW they spread. Virus = needs user to open/run something. Worm = spreads automatically across networks. This is a very common exam question.

1.3 Trojan

A **trojan** (or trojan horse) is malware disguised as legitimate, useful software. Users are tricked into installing it, believing it to be something helpful.

How trojans spread:

- Disguised as free games or utilities
- Hidden in pirated software or "cracked" applications
- Bundled with free downloads
- Attached to phishing emails as "important documents"

What trojans do:

- Create **backdoors** for attackers to access the system

- Steal login credentials and personal data
- Record keystrokes (keylogger)
- Give attackers remote control of the computer
- Install additional malware

Key characteristic: A trojan **disguises itself as something useful**. Unlike viruses and worms, trojans do not self-replicate — they rely on tricking users into installing them.

> **Why "trojan"?** The name comes from the ancient Greek story of the Trojan Horse — soldiers hid inside a giant wooden horse that was presented as a gift. Once inside the city walls, they emerged and attacked. Similarly, a trojan appears harmless but contains hidden malicious code.

1.4 Spyware

Spyware is malware that secretly monitors user activity and collects personal information without consent.

How spyware spreads:

- Bundled with free software installations
- Drive-by downloads from malicious websites
- Hidden in browser extensions or add-ons
- Installed via trojans or other malware

What spyware does:

- Records keystrokes (**keyloggers**) to capture passwords
- Tracks browsing history and online behaviour
- Captures screenshots of activity
- Accesses webcam and microphone
- Steals financial information and login credentials
- Sends collected data to attackers

Key characteristic: Spyware **operates secretly**, often without visible symptoms. Users may not realise they are being monitored.

1.5 Ransomware

Ransomware is malware that encrypts a victim's files and demands payment (ransom) for the decryption key.

How ransomware spreads:

- Malicious email attachments
- Clicking links in phishing emails
- Exploiting security vulnerabilities
- Drive-by downloads from compromised websites
- Through infected USB drives

What ransomware does:

- Encrypts files so they cannot be accessed
- Displays a ransom demand (often in cryptocurrency)
- Sets a deadline after which files may be permanently lost
- May threaten to publish stolen data
- Can spread to connected network drives and backups

Key characteristic: Ransomware **holds data hostage** by encrypting it and demanding payment. Even if paid, there's no guarantee files will be recovered.

Real-world example: The WannaCry ransomware attack (2017) affected over 200,000 computers in 150 countries, including the NHS in the UK. Hospitals had to cancel appointments and operations because they couldn't access patient records. The attack exploited a Windows vulnerability.

Worked Example 1 – Describing a type of malware

Question: Describe what is meant by a computer virus and explain how it spreads. [4 marks]

Model answer:
A virus is malicious software/malware that attaches itself to a legitimate file or program **(1)**.
When the infected file is opened or executed, the virus activates **(1)**.
Viruses spread by attaching to files that are then shared, such as via email attachments or USB drives **(1)**.
The virus requires user action to spread — the user must open or run the infected file **(1)**.

Exam tip: For "describe" questions, give a definition AND explain HOW it works. Don't just say "it damages files" — explain the mechanism.

Worked Example 2 – Comparing virus and worm

Question: Compare a virus and a worm. [4 marks]

Model answer:
A virus attaches to files and requires user action to spread (e.g., opening an infected attachment) **(1)**, whereas a worm is standalone and spreads automatically across networks without user action **(1)**.
A virus needs a host file to exist **(1)**, whereas a worm is self-contained and self-replicating **(1)**.

Exam tip: For comparison questions, make sure each point addresses BOTH items being compared. Use "whereas" or "but" to show the contrast.

Worked Example 3 – Identifying malware from a scenario

Question: A user downloads a free game from an unofficial website. After installing it, the user notices their computer is running slowly and their personal files have

been sent to an unknown email address. Identify the type of malware and explain your answer. [3 marks]

Model answer:
The malware is most likely a **trojan (1)**.
The malware was disguised as a legitimate/useful program (a free game) which is characteristic of a trojan **(1)**.
Once installed, it performed malicious actions (stealing personal files) without the user's knowledge **(1)**.

Exam tip: In scenario questions, look for KEY CLUES. "Disguised as legitimate software" = trojan. "Spread automatically across network" = worm. "Files encrypted, ransom demanded" = ransomware.

Worked Example 4 – Explaining ransomware

Question: A company finds that all their files have been encrypted and a message demands payment in Bitcoin to recover them. Name this type of attack and explain how it affects the organisation. [4 marks]

Model answer:
This is a **ransomware** attack **(1)**.
The organisation cannot access their files because they have been encrypted **(1)**.
Business operations may be disrupted or halted entirely because essential data is unavailable **(1)**.
The organisation faces a difficult choice: pay the ransom (with no guarantee of recovery) or lose the data; either way there is financial loss **(1)**.

Exam tip: When explaining impact, think about: data access, business operations, financial cost, reputation damage.

2. Social engineering

Social engineering is the manipulation of people into revealing confidential information or performing actions that compromise security. Instead of attacking technology directly, social engineering exploits human psychology — trust, fear, helpfulness, or curiosity.
Social engineering is often the weakest link in security because humans are more easily manipulated than well-configured systems. No matter how strong technical security is, if an employee can be tricked into revealing a password, the system is compromised.

2.1 Phishing

Phishing is a social engineering attack where criminals send fraudulent messages (usually emails) that appear to come from legitimate organisations, attempting to trick

recipients into revealing sensitive information.

How phishing works:

1. Attacker sends email appearing to be from a trusted source (bank, HMRC, Amazon, etc.)
2. Email creates urgency ("Your account will be suspended", "Unusual activity detected")
3. Email contains a link to a fake website that looks like the real one
4. Victim enters login details or personal information on the fake site
5. Attacker captures the information and uses it fraudulently

Signs of phishing:

- Generic greetings ("Dear Customer" instead of your name)
- Spelling and grammar errors
- Suspicious sender email addresses (e.g., support@amazOn-security.com)
- Urgency or threats ("Act now or your account will be closed")
- Links that don't match the claimed organisation
- Requests for sensitive information (passwords, card numbers)

> **Spear phishing** is a targeted form of phishing aimed at specific individuals or organisations. Attackers research their targets to make messages more convincing (e.g., using the target's name, job title, or recent activities).

2.2 Blagging (pretexting)

Blagging (also called pretexting) involves creating a fabricated scenario or identity to manipulate a victim into providing information or access.

How blagging works:

1. Attacker creates a convincing backstory or pretext
2. Attacker contacts the target (often by phone) pretending to be someone they're not
3. Attacker uses the pretext to request information or action
4. Target provides information believing they are helping a legitimate person

Common blagging scenarios:

- Pretending to be IT support: "I need your password to fix a system issue"
- Pretending to be a colleague: "I'm locked out — can you let me into the building?"
- Pretending to be from the bank: "We need to verify your account details"
- Pretending to be a new employee: "I haven't got my login yet — can I use yours?"

Key characteristic: Blagging relies on creating a **believable story** and often targets employees who are trying to be helpful.

2.3 Pharming

Pharming redirects users from legitimate websites to fraudulent ones without their knowledge, even when they type the correct URL.

How pharming works:

- The attacker manipulates the system that converts website addresses into computer-readable addresses
- When a user types a legitimate web address (e.g., www.mybank.com), they are automatically redirected to a fake site
- The user believes they are on the real site because they typed the correct address
- Malware on the victim's computer can also cause this redirection

Why pharming is dangerous:

- User types the correct URL but still reaches a fake site
- The fake site looks identical to the real one

- The user has no obvious warning signs
- Checking the URL won't help (it appears correct)

Key difference from phishing: Phishing requires the user to click a link. Pharming redirects users automatically, even when they type the correct address.

> **Exam tip:** Phishing = fake EMAIL with a link. Pharming = fake REDIRECTION at DNS level. This distinction is commonly tested. Remember: phishing needs user to click; pharming happens automatically.

2.4 Shouldering (shoulder surfing)

Shouldering (or shoulder surfing) is the act of observing someone entering sensitive information, such as watching them type a PIN or password.

How shouldering works:

- Attacker positions themselves to observe the victim's screen or keypad
- Victim enters PIN at ATM, cash register, or door keypad
- Attacker memorises or records the information
- Attacker uses the stolen information to access accounts or locations

Where shouldering occurs:

- At cash machines (ATMs) — watching PIN entry
- In shops — observing card PIN or contactless limit bypass
- At work — watching someone log in to their computer
- On public transport — reading sensitive information on screens
- At building entrances — observing door codes

Prevention:

- Shield keypad when entering PINs
- Be aware of people standing close by
- Use biometric authentication where possible
- Position screens away from public view
- Use privacy screen filters on devices

> **Low-tech but effective:** Shouldering requires no technical skills — just observation. It's a reminder that not all cyber threats involve sophisticated technology.

Worked Example 5 – Explaining phishing

Question: Describe what is meant by a phishing attack and explain how it works. [4 marks]

Model answer:
Phishing is a social engineering attack where criminals send fraudulent emails/messages that appear to come from legitimate organisations **(1)**.
The email typically contains a link to a fake website that looks like the real one (e.g., a fake bank website) **(1)**.
The victim is tricked into entering sensitive information such as login credentials or card details **(1)**.

The attacker captures this information and uses it fraudulently to access accounts or steal money **(1)**.

Exam tip: For phishing, always mention: fake email, link to fake website, victim enters details, attacker steals information.

Worked Example 6 — Comparing phishing and pharming

Question: Compare phishing and pharming attacks. [4 marks]

Model answer:
Phishing requires the user to click on a link in a fake email **(1)**, whereas pharming redirects users automatically without them clicking anything **(1)**.
Phishing attacks are easier to spot because the email or link may look suspicious **(1)**, whereas pharming is harder to detect because the user types the correct URL but is still redirected **(1)**.

Exam tip: The key contrast is: phishing = user action required (clicking link); pharming = automatic redirection. Both end up at a fake site, but the METHOD differs.

Worked Example 7 — Identifying social engineering from scenario

Question: An employee receives a phone call from someone claiming to be from the IT department. The caller says there is a problem with the employee's account and asks them to confirm their username and password. Identify the type of attack and explain how the employee should respond. [4 marks]

Model answer:
This is a **blagging** (pretexting) attack **(1)**.
The attacker has created a false scenario (IT problem) to trick the employee into revealing login credentials **(1)**.
The employee should never give out their password over the phone **(1)**.
They should verify the caller's identity by calling the IT department back using a known number, or by visiting them in person **(1)**.

Exam tip: Blagging involves creating a STORY or PRETEXT. Look for: phone calls, fabricated scenarios, requests for credentials.

Worked Example 8 — Explaining shouldering

Question: Describe what is meant by shouldering and give two ways it can be prevented. [4 marks]

Model answer:
Shouldering is observing someone as they enter sensitive information, such as watching them type a PIN or password **(1)**.
The attacker memorises or records the information and uses it to gain unauthorised access **(1)**.
Prevention 1: Shield the keypad with your hand when entering PINs at ATMs or payment terminals **(1)**.
Prevention 2: Be aware of your surroundings and check for people standing close enough to observe your screen or keyboard **(1)**.

Exam tip: Prevention answers should be specific and practical. "Be careful" is too vague — "shield the keypad with your hand" is specific and actionable.

3. Network attacks

Network attacks target computer systems, networks, and the data they contain. These attacks exploit technical vulnerabilities rather than relying on manipulating humans (though some combine both approaches).

3.1 Brute-force attacks

A **brute-force attack** attempts to gain access by systematically trying every possible combination of characters until the correct password is found.

How brute-force works:

1. Attacker uses automated software to try password combinations
2. Software tries combinations systematically (a, b, c... aa, ab, ac... aaa, aab...)
3. When the correct password is found, access is granted

Factors affecting success:

- **Password length:** Longer passwords take exponentially longer to crack
- **Character set:** Using lowercase, uppercase, numbers, and symbols increases combinations
- **Computing power:** Faster computers try more combinations per second
- **Account lockouts:** Systems that lock after failed attempts prevent brute-force

Password crack times (approximate):

- 4 lowercase letters: instant
- 6 lowercase letters: seconds
- 8 mixed characters: hours to days
- 12 mixed characters with symbols: years to centuries

Dictionary attacks are a variation that tries common words and passwords first (password123, qwerty, letmein) before moving to all combinations. This is faster because many people use predictable passwords.

3.2 Denial of Service (DoS) attacks

A **Denial of Service (DoS)** attack attempts to make a computer, server, or network unavailable by overwhelming it with traffic or requests.

How DoS works:

1. Attacker floods the target server with a massive number of requests
2. Server cannot process legitimate requests because it's overwhelmed
3. Website or service becomes slow or completely unavailable
4. Legitimate users cannot access the service

DDoS (Distributed Denial of Service):

A DDoS attack uses multiple computers (often a **botnet** — a network of infected computers) to attack simultaneously. This makes the attack more powerful and harder to stop because traffic comes from many different sources.

Impact of DoS attacks:

- Lost revenue for online businesses
- Damage to reputation and customer trust
- Cost of investigation and recovery
- May be used as a distraction for other attacks

> **Exam tip:** DoS makes services UNAVAILABLE — it doesn't steal data or destroy files. The goal is disruption, not theft. The "S" stands for "Service" — the attacker is denying the service to legitimate users.

3.3 Data interception and theft

Data interception involves capturing data as it travels across a network. This is often called a **man-in-the-middle (MITM)** attack because the attacker positions themselves between two communicating parties.

How data interception works:

1. Attacker positions themselves on the network between sender and receiver
2. Data packets pass through the attacker's system
3. Attacker captures and reads the data
4. Attacker may modify data before forwarding it, or simply record it

Where interception occurs:

- **Public WiFi:** Unsecured networks in cafés, hotels, airports
- **Fake hotspots:** Attacker creates a WiFi network with a legitimate-sounding name
- **Compromised routers:** Attacker gains access to network equipment
- **Network taps:** Physical devices attached to cables

What can be stolen:

- Login credentials (usernames, passwords)
- Financial information (card numbers, bank details)
- Personal data (emails, messages)
- Business data (confidential documents)

Prevention: Use encrypted connections (HTTPS, VPN), avoid public WiFi for sensitive activities, verify network authenticity.

3.4 SQL injection

SQL injection is an attack where malicious SQL code is inserted into input fields on a website to manipulate the database behind it.

How SQL injection works:

1. Website has a form (login, search, etc.) that sends input to a database
2. If the website doesn't validate input properly, attacker enters SQL code instead of normal text
3. The database executes the malicious SQL as part of the query
4. Attacker gains access to, modifies, or deletes database contents

> **Illustration only:** The example below shows how SQL injection works conceptually. You don't need to write SQL code at GCSE, but understanding the principle helps explain the attack.

```
-- Normal login query expected by the website:
SELECT * FROM users WHERE username = 'john' AND password = 'secret123';

-- Attacker enters this in the username field:
' OR '1'='1' --

-- Resulting query (password check bypassed):
SELECT * FROM users WHERE username = '' OR '1'='1' --' AND password =
'anything';

-- Since '1'='1' is always true, attacker gains access without valid
password
```

What attackers can do:

- Bypass login authentication
- View all data in the database (customer details, passwords)
- Modify or delete records
- Execute commands on the database server

Prevention: Input validation (checking and cleaning user input before processing), ensuring user input is treated as data rather than commands, limiting what the database can access.

> **Why SQL injection matters:** Many major data breaches have been caused by SQL injection. It's a well-known vulnerability, but websites still fail to protect against it properly.

Worked Example 9 — Explaining brute-force attacks

Question: Describe how a brute-force attack works and explain why using a longer password makes the attack less likely to succeed. [4 marks]

Model answer:

A brute-force attack systematically tries every possible combination of characters to guess a password **(1)**.
Automated software tests combinations until the correct password is found **(1)**.
Longer passwords have exponentially more possible combinations **(1)**.

This means it takes much longer to try all combinations, potentially making the attack impractical (years or centuries to complete) **(1)**.

Exam tip: The word "exponentially" is useful here. Each additional character MULTIPLIES the possible combinations, not just adds to them.

Worked Example 10 – Describing DoS attacks

Question: Describe what is meant by a denial of service (DoS) attack and explain its impact on a business. [4 marks]

Model answer:
A DoS attack floods a server or network with a massive number of requests **(1)**.
The server becomes overwhelmed and cannot respond to legitimate requests, making the service unavailable **(1)**.
For a business, this means customers cannot access the website, potentially causing lost sales and revenue **(1)**.
The business may also suffer damage to its reputation as customers lose trust in the reliability of the service **(1)**.

Exam tip: DoS = unavailability. Impact on business = lost revenue + reputation damage. Don't confuse with data theft.

Worked Example 11 – Explaining data interception

Question: Explain how data can be intercepted on a public WiFi network and describe one way to prevent this. [4 marks]

Model answer:
On public WiFi, an attacker can position themselves between the user and the network (man-in-the-middle) **(1)**.
As data travels across the network, the attacker can capture and read data packets containing sensitive information **(1)**.
The attacker may also create a fake WiFi hotspot with a legitimate-sounding name to trick users into connecting **(1)**.
Prevention: Use a VPN (Virtual Private Network) which encrypts all data between the user's device and the VPN server, making intercepted data unreadable **(1)**.

Exam tip: For prevention, be specific. "Use encryption" is acceptable, but "use a VPN which encrypts all data" is better.

Worked Example 12 – Describing SQL injection

Question: Describe what is meant by an SQL injection attack and explain how it can be prevented. [4 marks]

Model answer:
SQL injection is an attack where malicious SQL code is entered into a website's input field (such as a login form) **(1)**.
If the website doesn't validate the input, the malicious code is executed by the database, allowing the attacker to access, modify, or delete data **(1)**.
Prevention 1: Input validation — checking and cleaning all user input before it is processed **(1)**.
Prevention 2: Ensuring the website treats user input as data only, not as commands that can be executed **(1)**.

Exam tip: SQL injection exploits WEBSITES with forms that connect to databases. The key issue is that user input is not validated/sanitised.

Worked examples summary

The 12 worked examples above cover the main question types you will encounter on cyber security threats. Here is a summary of the key question patterns:

Example	Question type	Key skill
1	Describe virus (4 marks)	Definition + spreading mechanism
2	Compare virus/worm (4 marks)	Spreading method + self-replication
3	Identify from scenario (3 marks)	Recognise trojan characteristics
4	Explain ransomware (4 marks)	Name attack + impact on organisation
5	Describe phishing (4 marks)	Fake email + fake website + data theft
6	Compare phishing/pharming (4 marks)	User action vs automatic redirection
7	Identify blagging (4 marks)	Fabricated scenario + how to respond

Example	Question type	Key skill
8	Explain shouldering (4 marks)	Definition + prevention methods
9	Brute-force explanation (4 marks)	Method + password length importance
10	DoS description (4 marks)	How it works + business impact
11	Data interception (4 marks)	Public WiFi + VPN prevention
12	SQL injection (4 marks)	Definition + prevention methods

Quick reference

Key terms — exam-ready definitions

Term	Definition (mark scheme style)
Malware	Malicious software designed to damage, disrupt, or gain unauthorised access to a computer system
Virus	Malware that attaches to files; requires user action to spread; can corrupt/delete data
Worm	Self-replicating malware that spreads across networks automatically without user action
Trojan	Malware disguised as legitimate software; does not self-replicate; creates backdoors
Spyware	Malware that secretly monitors user activity and steals personal information
Ransomware	Malware that encrypts files and demands payment for the decryption key
Social engineering	Manipulating people into revealing confidential information or performing insecure actions
Phishing	Fake emails/messages that trick users into clicking links to fraudulent websites
Blagging	Creating a fabricated scenario to trick someone into providing information or access
Pharming	Redirecting users to fake websites automatically, even when they type the correct URL
Shouldering	Observing someone entering sensitive information (e.g., watching PIN entry)

Term	Definition (mark scheme style)
Brute-force	Systematically trying all possible password combinations until the correct one is found
DoS	Denial of Service; flooding a server with requests to make it unavailable
DDoS	Distributed DoS; using multiple computers (botnet) to attack simultaneously
Data interception	Capturing data as it travels across a network (man-in-the-middle attack)
SQL injection	Inserting malicious SQL code into website input fields to manipulate the database
Botnet	Network of infected computers controlled by an attacker, often used for DDoS attacks

Attack identification guide

Clue in scenario	Attack type
Files encrypted, ransom demanded	**Ransomware**
Spreads across network without user action	**Worm**
Disguised as free/useful software	**Trojan**
Email with link to fake website	**Phishing**
Phone call with fabricated story	**Blagging**
Correct URL but wrong website	**Pharming**
Watching someone enter PIN	**Shouldering**
Website unavailable, overwhelmed by traffic	**DoS/DDoS**
Trying all password combinations	**Brute-force**
Malicious code in login form	**SQL injection**
Data captured on public WiFi	**Data interception**
Secretly recording keystrokes	**Spyware (keylogger)**

Social engineering vs technical attacks

Social engineering (targets humans)	Technical attacks (targets systems)
Phishing	Brute-force
Blagging	DoS/DDoS
Pharming	SQL injection
Shouldering	Data interception

Typical pitfalls

Pitfall 1 — Confusing virus and worm.
Wrong: "A virus spreads automatically across networks."
Right: A **worm** spreads automatically. A **virus** requires user action (opening a file).

Pitfall 2 — Confusing phishing and pharming.
Wrong: "Pharming is when you get a fake email."
Right: Phishing uses fake emails. **Pharming** redirects at DNS level without needing the user to click anything.

Pitfall 3 — Saying DoS steals data.
Wrong: "DoS attacks steal customer data."
Right: DoS attacks make services **unavailable**. They don't steal data — they deny access.

Pitfall 4 — Vague malware descriptions.
Wrong: "Ransomware is bad software that affects your computer."
Right: "Ransomware **encrypts files** and **demands payment** for the decryption key."

Pitfall 5 — Missing the "social" in social engineering.
Wrong: Describing technical details of network attacks.
Right: Social engineering targets **humans**, not technology. It exploits trust, fear, or helpfulness.

Pitfall 6 — Incomplete brute-force explanation.
Wrong: "Brute-force tries lots of passwords."
Right: "Brute-force **systematically tries all possible combinations** until the correct password is found."

Pitfall 7 — Not explaining HOW trojans work.
Wrong: "A trojan is malware that damages your computer."

Right: "A trojan is **disguised as legitimate software**. Users are tricked into installing it."

Pitfall 8 — Generic prevention answers.
Wrong: "Use good security."
Right: Be specific: "Use a VPN", "Enable two-factor authentication", "Check and clean all user input before processing".

Pitfall 9 — Not relating answer to scenario.
Wrong: Giving a generic definition without addressing the scenario.
Right: Link your answer to the specific details in the question (e.g., "The free game download is characteristic of a trojan").

Pitfall 10 — Confusing spyware with other malware.
Wrong: "Spyware encrypts your files."
Right: Spyware **secretly monitors** activity and **steals data**. Ransomware encrypts files.

Assessment Hub | Long-Answer | Notes Index

Williams Physics Education — over **1,100,000+ marks** of exam-aligned content and **4,200+ auto-marked assessments** across 67 qualifications at GCSE, A-Level, AP & Professional Qualifications. Free to use, no login required.

About & Contact • Privacy • Terms • Accessibility • Copyright • DMCA • YouTube

WPE is free for everyone. If our resources help you or your students, you can support the project here.

© 2026 Williams Physics Education. All rights reserved.